



Communauté Française de Belgique

Institut des Carrières Commerciales

Ville de Bruxelles

Waterside

Quai de Willebroeck, 33

1000 Bruxelles



Stratégie de sécurité

Tarik EL MAHTOUCI

2025-2026

Table des matières

1. Introduction.....	2
2. Authentification et récupération des identifiants.....	2
3. Techniques d'autorisation.....	2
4. Accès aux ressources et aux fonctionnalités.....	2
5. Protection des données personnelles.....	2
6. Sécurité applicative.....	2
7. Conformité RGPD.....	3
8. Détection d'intrusion (IDS).....	3
9. Plan de reprise d'activité.....	3
10. Recommandations de production.....	3
11. Conclusion.....	3

1. Introduction

Ce rapport présente une réflexion documentée sur les besoins de sécurisation de l'application BikeShare. Il couvre les systèmes d'authentification, les techniques d'autorisation, l'accès aux ressources et aux fonctionnalités, la protection des données personnelles, la sécurité applicative, la conformité RGPD, la détection d'intrusion (IDS) et le plan de reprise d'activité.

2. Authentification et récupération des identifiants

BikeShare repose sur Spring Security et l'algorithme de hachage BCrypt pour sécuriser les mots de passe. Ceux-ci ne sont jamais stockés en clair : ils sont hachés avec un sel unique, ce qui rend les attaques par force brute beaucoup plus difficiles.

- Récupération de mot de passe par e-mail sécurisé, via un lien à durée de validité limitée.
- Évolution prévue : JSON Web Tokens (JWT) pour une gestion de session sans état (stateless) et l'authentification des requêtes API.

3. Techniques d'autorisation

L'autorisation s'appuie sur des rôles définis : ROLE_VISITOR, ROLE_MEMBER et ROLE_ADMIN. Spring Security vérifie chaque requête avant d'accorder l'accès aux ressources. Les politiques d'accès limitent les actions des utilisateurs selon leur rôle, garantissant une attribution appropriée des privilèges.

4. Accès aux ressources et aux fonctionnalités

Les accès aux ressources (vélos, informations des utilisateurs) sont strictement contrôlés via SecurityFilterChain, qui cloisonne les zones publiques, l'espace membre et l'espace administrateur.

- Vérification des permissions à chaque endpoint sensible.
- Données sensibles (paiements) accessibles uniquement aux utilisateurs autorisés.
- Utilisation de DTO (Data Transfer Objects) pour n'exposer que les informations nécessaires et limiter les risques de fuite.

5. Protection des données personnelles

La protection des données est une priorité. Les données sont chiffrées en transit (HTTPS/TLS). Les données bancaires (IBAN/BIC) ne sont pas exposées et les paiements sont délégués à Stripe : aucune donnée de carte n'est stockée côté serveur.

- Validation des entrées (annotations @NotBlank, @Pattern, @Size) pour prévenir les données malformées.
- Vérification d'identité des profils via documents (table documents).
- Accès aux données personnelles limité aux seules personnes et systèmes nécessaires au fonctionnement.

6. Sécurité applicative

Risque	Mesure
Injection SQL	Requêtes paramétrées via Spring Data JPA / Hibernate.
Accès non autorisé	Contrôle par rôle sur chaque endpoint sensible.

Risque	Mesure
Détournement de session	Gestion de session sécurisée, HTTPS imposé en production.
Téléversement malveillant	Limitation de taille et stockage isolé des fichiers (FileStorageService).
Attaque CSRF	Protection CSRF activée sur les formulaires.

7. Conformité RGPD

- Minimisation des données collectées et finalité explicite.
- Consentement de l'utilisateur lors de l'inscription.
- Droit d'accès, de rectification et à l'effacement des données.
- Conservation des données limitée aux durées nécessaires.

8. Détection d'intrusion (IDS)

L'implémentation d'un système de détection d'intrusion (IDS) est prévue pour surveiller les anomalies et les comportements suspects sur la plateforme. Une fois en place, l'IDS analysera les journaux d'accès et les requêtes API afin d'identifier tout comportement anormal et de générer des alertes en cas d'activité non autorisée.

9. Plan de reprise d'activité

Un plan de reprise d'activité (Disaster Recovery Plan) garantira la continuité du service en cas de sinistre : sauvegardes régulières des données stockées hors site et testées, procédures de restauration en cas de panne, et déploiement redondant des services critiques pour minimiser les interruptions.

10. Recommandations de production

Forcer HTTPS (TLS) sur l'ensemble du site, activer la protection CSRF pour les formulaires, journaliser les accès sensibles et mettre en place une politique de mots de passe robuste.

11. Conclusion

La stratégie de sécurité de BikeShare assure une protection complète des comptes, des données personnelles et des transactions. Grâce à une authentification robuste (Spring Security + BCrypt), à un contrôle d'accès par rôle, à la délégation des paiements à Stripe et au respect du RGPD, la plateforme offre un environnement sécurisé. L'intégration future des JWT et d'un IDS renforcera encore cette sécurité.